

Security Checklist

Java_The_Hutt

COM2020 Team Project

User Authentication

A secure login system has been implemented to ensure all users can login safely using the login page, including a create account page for unauthenticated users. A user can be assigned one of three roles including *Viewer*, *Curator* and *Admin* through a Role-Based Access Control System. Admins are able to manage roles; create, edit and delete exhibits and quizzes; and add and delete comments on different exhibits. Curators can add and edit exhibits but cannot manage roles. Viewers can simply view and leave comments. All user's passwords are hashed.

Input Validation and Injection Protection

In certain areas of the website, users can input texts into different fields. To protect from specific attacks such as SQL injections or XSS, certain fields cannot contain special characters and are fully sanitised.

Data Protection

All data is securely encrypted in transit via HTTPS and is securely stored in the Django database used for the website. No data is hardcoded within programs.

Secure Configuration

Users can incorrectly enter credentials into the website and a correct error message will come up. Errors such as incorrect passwords or invalid field values will return an appropriate response without leaking information. An ADMIN account can be created in the local space but is not available in a real-world deployment. All users have to enter a password with no default setting available.

Dependency & Software Security

All libraries are up to date on release and contain no known vulnerabilities.

Area	Check	Status	Notes
Authentication	Password hashing		sha256 used
Authentication	Protected endpoints		Roles can access respective endpoints
Authentication	Login		Users must log in to use authenticated features
Authentication	RBAC		Admin, Curator and Viewer with no scope creep
Input Validation	Frontend and backend		
Input Validation	SQL injection prevention		Sanitised
Input Validation	XXS protection		Sanitised
Data Protection	HTTPS		By default
Data Protection	Sensitive data protected		All passwords hashed
Data Protection	Database access restricted		Only accessible in backend (ADMINS)
Secure Config	Error handling		All incorrect fields show appropriate messages
RBAC	No permission creep		All roles have the correct permissions
RBAC	Admins protected		Only admins can edit roles
Dependency and Software	Dependencies contain no vulnerabilities		No known vulnerabilities
Dependency and Software	All libraries up to date		Regular updates
Testing	Automatic		Test files all pass
Testing	Manuel		Tested on the website and no issues or vulnerabilities